

Q/CUP

中国银联股份有限公司企业标准

Q/CUP 047.4—2014
代替Q/CUP 047.4-2012

中国银联 IC 卡技术规范——产品规范 第 4 部分 数字证书应用规范

China UnionPay integrated circuit card specification

Part 4 Digital Certificate Specification

2014-11-30 发布

2014-11-30 实施

中国银联股份有限公司 发布

中国银联股份有限公司（以下简称“中国银联”）对该规范文档保留全部知识产权权利，包括但不限于版权、专利、商标、商业秘密等。任何人对该规范文档的任何使用都要受限于在中国银联成员机构服务平台（<http://member.unionpay.com/>）与中国银联签署的协议之规定。中国银联不对该规范文档的错误或疏漏以及由此导致的任何损失负任何责任。中国银联针对该规范文档放弃所有明示或暗示的保证,包括但不限于不侵犯第三方知识产权。

未经中国银联书面同意，您不得将该规范文档用于与中国银联合作事项之外的用途和目的。未经中国银联书面同意，不得下载、转发、公开或以其它任何形式向第三方提供该规范文档。如果您通过非法渠道获得该规范文档，请立即删除，并通过合法渠道向中国银联申请。

中国银联对该规范文档或与其相关的文档是否涉及第三方的知识产权（如加密算法可能在某些国家受专利保护）不做任何声明和担保，中国银联对于该规范文档的使用是否侵犯第三方权利不承担任何责任，包括但不限于对该规范文档的部分或全部使用。

目 录

目 录	I
前 言	VI
1 范围	7
2 规范性引用文件	7
3 术语和定义	8
3.1 块 Block	8
3.2 接口设备 Interface Device	8
3.3 终端 Terminal	8
3.4 命令 Command	8
3.5 连接 Concatenation	8
3.6 触点 Contact	8
3.7 响应 Response	8
3.8 头域 Prologue Field	8
3.9 尾域 Epilogue Field	8
3.10 功能 Function	8
3.11 保护时间 Guard time	8
3.12 哈希函数 Hash Function	8
3.13 哈希结果 Hash Result	9
3.14 静止状态 Inactive	9
3.15 集成电路 Integrated Circuit (IC)	9
3.16 集成电路卡 (IC 卡) Integrated Circuit (s) Card	9
3.17 报文 Message	9
3.18 报文认证码 Message Authentication Code	9
3.19 半字节 Nibble	9
3.20 明文 Plain Text	9
3.21 密文 Cipher Text	9
3.22 密钥 Key	9
3.23 数字签名 Digital Signature	9
3.24 加密算法 Cryptographic Algorithm	9
3.25 认证机构 Certification Authority	9
3.26 对称加密技术 Symmetric Cryptographic Technique	9
3.27 非对称加密算法 Asymmetric Cryptographic Technique	9
3.28 私有密钥 Private Key	9
3.29 公共密钥 Public Key	9
3.30 公共密钥认证 Public Key Certification	9
3.31 保护密钥 Secret Key	9
3.32 数据完整性 Data Integrity	9
4 符号和缩略语	10

5 机电特性、逻辑接口与传输协议	12
6 数字证书应用流程	13
6.1 数字证书应用实现构架	13
6.2 数字证书应用流程——证书申请/更新	13
6.3 数字证书应用流程——签名和认证	14
7 安全机制	15
7.1 基本安全要求	15
7.1.1 共存应用	16
7.1.2 密钥的独立性	16
7.1.3 密钥和用户密码(PIN)的存放	16
7.1.4 用户密码(PIN)的验证	16
7.2 安全报文传送	16
7.2.1 安全报文传送格式	16
7.2.2 报文完整性和验证	16
7.2.3 数据可靠性	18
7.2.4 安全报文传送的命令情况	21
7.3 认可的加密算法	22
7.3.1 对称算法(DES)	22
7.3.2 非对称算法(RSA)	22
7.3.3 安全哈希算法(SHA-1)	23
7.3.4 对称算法(SM1)	23
7.3.5 非对称算法(SM2)	23
7.3.6 摘要算法(SM3)	23
8 命令	23
8.1 C-APDU 格式	23
8.2 R-APDU 格式	24
8.3 Create File (创建文件)	24
8.3.1 定义和范围	24
8.3.2 命令报文	24
8.3.3 命令报文数据域	25
8.3.4 响应报文数据域	25
8.3.5 响应报文状态码	25
8.4 Compute Digital Signature (数字签名计算)	25
8.4.1 定义和范围	25
8.4.2 命令报文	25
8.4.3 命令报文数据域	26
8.4.4 响应报文数据域	26
8.4.5 响应报文状态码	26
8.5 Compute HASH (HASH 计算)	26
8.5.1 定义和范围	26
8.5.2 命令报文	26
8.5.3 命令报文数据域	26
8.5.4 响应报文数据域	27
8.5.5 响应报文状态码	27

8.6 Encipher/Decipher（加/解密）	27
8.6.1 定义和范围	27
8.6.2 命令报文	27
8.6.3 命令报文数据域	27
8.6.4 响应报文数据域	27
8.6.5 响应报文状态码	27
8.7 Verify PIN（PIN 验证）	28
8.7.1 定义和范围	28
8.7.2 命令报文	28
8.7.3 命令报文数据域	28
8.7.4 响应报文数据域	28
8.7.5 响应报文状态码	28
8.8 Get Challenge（取随机数）	28
8.8.1 定义和范围	28
8.8.2 命令报文	29
8.8.3 命令报文数据域	29
8.8.4 响应报文数据域	29
8.8.5 响应报文状态码	29
8.9 Generate Asymmetric Key(生成公私钥对)	29
8.9.1 定义和范围	29
8.9.2 命令报文	29
8.9.3 命令报文数据域	29
8.9.4 响应报文数据域	30
8.9.5 响应报文状态码	30
8.10 Manage Security Environment（安全环境管理）	30
8.10.1 定义和范围	30
8.10.2 命令报文	30
8.10.3 命令报文数据域	30
8.10.4 响应报文数据域	31
8.10.5 响应报文状态码	31
8.11 Perform Security Operation(安全操作)	31
8.12 Read Binary（读取二进制文件）	32
8.12.1 定义和范围	32
8.12.2 命令报文	32
8.12.3 命令报文数据域	32
8.12.4 响应报文数据域	32
8.12.5 响应报文状态码	32
8.13 Read Record（读取记录文件）	32
8.13.1 定义和范围	32
8.13.2 命令报文	32
8.13.3 命令报文数据域	33
8.13.4 响应报文数据域	33
8.13.5 响应报文状态码	33
8.14 Update Binary（更新二进制文件）	33

8.14.1 定义和范围	33
8.14.2 命令报文	33
8.14.3 命令报文数据域	33
8.14.4 响应报文数据域	33
8.14.5 响应报文状态码	33
8.15 Update Record（更新记录文件）	34
8.15.1 定义和范围	34
8.15.2 命令报文	34
8.15.3 命令报文数据域	34
8.15.4 响应报文数据域	34
8.15.5 响应报文状态码	34
8.16 Verify Signature（签名验证）	34
8.16.1 定义和范围	34
8.16.2 命令报文	35
8.16.3 命令报文数据域	35
8.16.4 响应报文数据域	35
8.16.5 响应报文状态码	35
8.17 Write PIN(装载或更新 PIN).....	35
8.17.1 定义和范围	35
8.17.2 命令报文	35
8.17.3 命令报文数据域	36
8.17.4 响应报文数据域	36
8.17.5 响应报文状态码	36
附录 A 基本数据文件（EF）	37
附录 B 非对称密钥的装载.....	40
附录 C 读卡终端配置建议	42

前 言

本标准是依据《中国银联IC卡技术规范》借记贷记规范以及其它相关的标准制定。

本标准阐述了UICS金融IC卡数字证书应用相关内容。

本标准由中国银联股份有限公司提出。

本标准由中国银联股份有限公司产品部组织制定。

本标准主要起草单位：中国银联产品部。

本标准主要起草人：肖波、李春欢、海涛、杨辅祥、周鑫、陈朋、鲍强。

中国银联 IC 卡技术规范——应用规范

第 4 部分 数字证书应用规范

1 范围

本部分规定了数字证书应用卡片方面的内容，包括卡片的机电特性、逻辑接口和传输协议，数据元和命令，及数字证书应用卡的安全机制，其中：

- 机电接口、逻辑接口和传输协议。用于卡和终端间的信息交换。
- 数据元和命令集。定义了数字证书应用中所使用的一般数据元、命令集和对终端响应的基本要求。
- 安全机制。定义了数字证书应用中有关安全的总体要求、加密算法和安全机制。

本部分适用于由银行发行或受理的支持数字证书应用的金融 IC 卡。其使用对象主要是与支持数字证书应用的金融 IC 卡相关的卡片设计、制造、管理、发行、受理以及应用系统的研制、开发、集成和维护等部门（单位），也可以作为其他行业 IC 卡应用的参考。

2 规范性引用文件

下列文件中的条款通过本部分的引用而成为本部分的条款。凡是注日期的引用文件，其随后所有的修改单（不包括勘误的内容）或修订版均不适用于本部分，然而，鼓励根据本部分达成协议的各方研究是否可使用这些文件的最新版本。凡是不注日期的引用文件，其最新版本适用于本部分。

- GB 2659—1994 世界各国和地区名称代码(ISO 3166:1993)
- GB/T 12406—1996 表示货币和资金的代码(ISO 4217:1995)
- GB/T 15120.1 识别卡 记录技术 第 1 部分：凸印 (ISO/IEC 7811-1:1992)
- GB/T 15120.3 识别卡 记录技术 第 3 部分：ID-1 型卡上凸印字符的位置 (ISO/IEC 7811-3:1992)
- GB/T 16649.1—1996 识别卡 带触点的集成电路卡 第 1 部分：物理特性(ISO/IEC 7816-1:1987)
- GB/T 16649.2—1996 识别卡 带触点的集成电路卡 第 2 部分：触点的尺寸和位置(ISO/IEC 7816-2:1988)
- GB/T 16649.3—1996 识别卡 带触点的集成电路卡 第 3 部分：电信号和传输协议(ISO/IEC 7816-3:1989)
- GB/T 16649.4—1995 识别卡 带触点的集成电路卡 第 4 部分：行业间交换用命令(ISO/IEC 7816-4:1995)
- GB/T 16649.5—1994 识别卡 带触点的集成电路卡 第 5 部分：应用标识符的编号系统和注册程序(ISO/IEC 7816-5:1994)
- GB/T 16649.6—1995 识别卡 带触点的集成电路卡 第 6 部分：行业间数据元(国际标准草案)
- GB/T 16263—1996 信息技术 开放系统互联 抽象语法表示 1(ASN.1)的基本编码规则(ISO/IEC 8825:1990)
- GB/T 15150—1996 产生报文的银行卡 交换报文规范 金融交易内容 (ISO 8583:1987)
- GB/T 15273 信息处理八位单字节代码型图型字符集 (ISO 8859:1987)
- GB/T 17552—1998 识别卡 金融交易卡 (ISO/IEC 7813:1995)
- ISO 639:1988 名称及语言表示代码
- ISO 8731-1:1987 银行业务 已批准的报文鉴别算法 第 1 部分：DEA
- ISO 8732:1987 信息处理 64 位块加密算法的运算方法
- ISO 8583:1993 产生报文的银行卡 交换报文规范 金融交易内容

- IEC 512-2:1979 机电设备机电器件规范 第2部分：触点电阻测试、绝缘测试和电压测试
- ISO/IEC 7816-3—1992 识别卡 带触点的集成电路卡 第3部分：电信号和传输协议 修订稿 1:T=1, 异步半双工块传输协议
- ISO/IEC 7816-3—1994 识别卡 带触点的集成电路卡 第3部分：电信号和传输协议 修订稿 2: 协议类型选择(国际标准草案)
- ISO/IEC 9796-2 信息技术 安全技术 报文恢复的数字签名方法 第2部分：使用哈希函数的机制
- ISO/IEC 9797:1993 信息技术 安全技术 使用块加密算法进行加密检查的数据完整性机制
- ISO/IEC 10116:1993 信息技术 安全技术 哈希函数 第3部分：专用哈希函数
- ISO/IEC 10373:1993 识别卡 测试方法
- FIPS Pub 180-1:1995 安全哈希标准
- EMV 支付系统集成电路卡规范：2004，第1册～第4册

3 术语和定义

以下术语定义适用于本部分。

3.1 块 Block

包含两个或三个域（头域、信息域、尾域）的字符组。

3.2 接口设备 Interface Device

终端上插入 IC 卡的部分，包括其中的机械和电气部分。

3.3 终端 Terminal

为完成数字证书交易而在交易点安装的设备，用于同 IC 卡的连接。它包括接口设备，也可包括其他部件和接口，例如与主机通讯的接口。

3.4 命令 Command

终端向 IC 卡发出的一条信息，该信息启动一个操作或请求一个应答。

3.5 连接 Concatenation

两个元素的连接是指将第二个元素附加到第一个元素的末尾。每个元素的字节在结果串中的排列顺序与其从 IC 卡发送到终端的顺序相同，即：高位字节先送。每个字节位按照从最高位到最低位的顺序排列。一组元素或对象可以通过最先两个相连的方式连接成一个新元素，即第一个与第二个相连，再与第三个相连，…，依次类推。

3.6 触点 Contact

在集成电路卡 and 外部接口设备之间保持电流连续性的导电元件。

3.7 响应 Response

IC 卡处理完成收到的命令报文后，返回给终端的报文。

3.8 头域 Prologue Field

块的第一部分，包括节点地址（AD）、协议控制字节（PCB）和长度（LEN）。

3.9 尾域 Epilogue Field

块的最后一部分，包括错误校验代码（EDC）位。

3.10 功能 Function

由一个或多个命令实现的处理过程，其操作结果用于完成全部或部分交易。

3.11 保护时间 Guard time

同一方向发送的前一个字符奇偶位下降沿和后一个字符起始位下降沿之间的最小时间。

3.12 哈希函数 Hash Function

将位串映射为定长位串的函数，它满足以下两个条件：

- 对于一个给定的输出，不可能推导出与之相对应的输入数据；
- 对于一个给定的输入，不可能推导出第二个能得出相同输出的输入数据。

另外，如果要求哈希函数具备防冲突功能，则还应满足以下条件：

- 不可能找到任意两个不同的输入，得出相同的输出数据。
- 3.13 哈希结果 Hash Result
哈希函数的输出位串。
- 3.14 静止状态 Inactive
当IC卡上的电源电压(VCC)和其他信号相对于地的电压值小于或等于0.4伏时，则称电源电压和这些信号处于静止状态。
- 3.15 集成电路 Integrated Circuit (IC)
设计用于完成处理和/或存储功能的电子器件。
- 3.16 集成电路卡 (IC 卡) Integrated Circuit (s) Card
内部封装一个或多个集成电路的ID-1型卡(如ISO7810、ISO7811第1至第5部分、ISO7812和ISO7813中描述的)。
- 3.17 报文 Message
由终端向卡或卡向终端发出的，不含传输控制字符的字节串。
- 3.18 报文认证码 Message Authentication Code
对交易数据及其相关参数进行运算后产生的代码。主要用于验证报文的完整性。
- 3.19 半字节 Nibble
一个字节的高四位或低四位。
- 3.20 明文 Plain Text
没有加密的信息。
- 3.21 密文 Cipher Text
通过密码系统产生的不可理解的文字或信号。
- 3.22 密钥 Key
控制加密转换操作的符号序列。
- 3.23 数字签名 Digital Signature
一种非对称加密数据变换，它使得接收方能够验证数据的原始性和完整性，保护发送和接收的数据不被第三方伪造，同时对于发送方来说，还可用以防止接收方的伪造。
- 3.24 加密算法 Cryptographic Algorithm
为了隐藏或揭露信息内容而变换数据的算法。
- 3.25 认证机构 Certification Authority
利用公开密钥和其他相关数据为所有者提供可靠校验的第三方机构。
- 3.26 对称加密技术 Symmetric Cryptographic Technique
发送方和接收方使用相同保密密钥进行数据变换的加密技术。在不掌握保密密钥的情况下，不可能推导出发送方或接收方的数据变换。
- 3.27 非对称加密算法 Asymmetric Cryptographic Technique
采用两种相关变换进行加密的技术，一种是公开变换(由公共密钥定义)，另一种是私有变换(由私有密钥定义)。这两种变换具有以下属性，即私有变换不能通过给定的公开变换导出。
- 3.28 私有密钥 Private Key
一个实体的非对称密钥对中仅供实体自身使用的密钥，在数字签名模式中，私有密钥用于签名功能。
- 3.29 公共密钥 Public Key
一个实体的非对称密钥对中公开的密钥，在数字签名模式中，公共密钥用于验证功能。
- 3.30 公共密钥认证 Public Key Certification
由认证机构签发的一个实体的公共密钥信息，具有不可伪造性。
- 3.31 保护密钥 Secret Key
对称加密技术中仅供指定实体所用的密钥。
- 3.32 数据完整性 Data Integrity

数据不受未经许可的方法变更或破坏的属性。

4 符号和缩略语

以下缩略语和符号表示适用于本部分

ADF	应用定义文件(Application Definition File)
AID	应用标识符(Application Identifier)
An	字母数字型(Alphanumeric)
Ans	字母数字及特殊字符型(Alphanumeric Special)
APDU	应用协议数据单元(Application Protocol Data Unit)
ASN.	抽象语法表示(Abstract Syntax Notation)
ATR	复位应答(Answer to Reset)
B	二进制(Binary)
BER	基本编码规则(Basic Encoding Rules)
BGT	块保护时间(Block Guard Time)
BWI	块等待时间整数(Block Waiting Time Integer)
BWT	块等待时间(Block Waiting Time)
C-APDU	命令APDU(Command APDU)
CBC	加密数据块链(Cipher Block Chaining)
CIN	输入电容(Input Capacitance)
CLA	命令报文的类别字节(Class Byte of the Command Message)
cn	压缩数字(Compressed numeric)
C-TPDU	命令TPDU(Command TPDU)
DAD	目标节点地址(Destination Node Address)
DDF	目录定义文件(Directory Definition File)
DEA	数据加密算法(Data Encryption Algorithm), 本部分中DEA算法就是指DES算法
DES	数据加密标准(Data Encryption Standard)
DF	专用文件(Dedicated File)
DIR	目录(Directory)
EDC	错误检测代码(Error Detection Code)
EF	基本文件(Elementary File)
EMV	Europay、Mastercard、VISA
Etu	基本时间单元(Elementary Time Unit)
FCI	文件控制信息(File Control Information)
F	频率(Frequency)
FIPS	联邦信息处理标准(Federal Information Processing Standard)
GND	地(Ground)
Hex.	十六进制数(Hexadecimal)
HHMM	时、分(Hours, Minutes)
HHMMSS	时、分、秒(Hours, Minutes, Seconds)
I-block	信息块(Information Block)
IC	集成电路(Integrated Circuit)
ICC	集成电路卡(Integrated Circuit Card)
IEC	国际电工委员会(International Electrotechnical Commission)
IFD	接口设备(Interface Device)
IFS	信息域大小(Information Field Size)

IFSC	IC卡信息域大小(Information Field Size for the ICC)
IFSD	终端信息域大小(Information Field Size for the Terminal)
INF	信息域(Information Field)
INS	命令报文的指令字节(Instruction Byte of Command Message)
I/O	输入/输出(Input/Output)
ISO	国际标准化组织(International Organization for Standardization)
KM	主控密钥(Master Key)
KS	过程密钥(Session Key)
Lc	终端发出的命令数据的实际长度(Exact Length of Data Sent by the TAL IN A Case 3 or 4 Command)
Lcm	最小公倍数(Least Common Multiple)
Le	响应数据的最大期望长度(Maximum Length of Data Expected by the TAL in Response to a Case 2 or 4 Command)
Licc	IC卡回送的可用数据的实际长度(Exact Length of Data Available in the ICC to be Returned in Response to the Case 2 or 4 Command Received by the ICC)
LEN	长度(Length)
Lr	响应数据域的长度(Length of Response Data Field)
LRC	冗余校验(Longitudinal Redundancy Check)
M	必备型(Mandatory)
MAC	报文认证码(Message Authentication Code)
MF	主控文件(Mater File)
N	数字型(Numeric)
NAD	节点地址(Node Address)
NAK	否定的确认(Negative Acknowledgment)
NCA	认证机构公开密钥模数长度(Length of the Certification Authority Public Key Modulus)
NI	发卡方公开密钥模数长度(Length of the Issuer Public Key Modulus)
NIC	IC卡公开密钥模数长度(Length of the ICC Public Key Modulus)
O	可选型(Optional)
P1	参数1(Parameter 1)
P2	参数2(Parameter 2)
P3	参数3(Parameter 3)
PCA	验证机构公开密钥(Certification Authority Public Key)
PCB	协议控制字节(Protocol Control Byte)
PI	数字证书应用发卡方公开密钥(Issuer Public Key)
PIC	数字证书应用IC卡公开密钥(ICC Public Key)
PIN	个人密码(Personal Identification Number)
PIX	专用应用标识符扩展码(Proprietary Application Identifier Extension)
PSA	支付系统应用(Payment System Application)
PSE	支付系统环境(Payment System Environment)
PTS	协议类型选择(Protocol Type Selection)
R-APDU	响应APDU(Response APDU)
RFU	保留为将来使用(Reserved for Future Use)
RID	已注册的应用提供者标识(Registered Application Provider Identifier)
RSA	一种非对称加密算法(Rivest, Shamir, Adleman)

RST	复位(Reset)
R-TPDU	响应TPDU(Response TPDU)
SAD	源节点地址(Source Node Address)
SAM	安全存取模块(Secure Access Module)
SCA	验证机构私有密钥(Certification Authority Private Key)
SI	数字证书应用发卡方私有密钥(Issuer Private Key)
SIC	数字证书应用IC卡私有密钥(ICC Private Key)
SFI	短文件标识符(Short File Identifier)
SHA	安全哈希算法(Secure Hash Algorithm)
SM1	国产对称算法
SM2	国产非对称算法
SM3	国产摘要算法
SW1	状态码1(Status Word One)
SW2	状态码2(Status Word Two)
TCK	校验字符(Check Character)
TLV	标签、长度、值(Tag Length Value)
TPDU	传输协议数据单元(Transport Protocol Data Unit)
TTL	终端传输层(Terminal Transport Layer)
TVR	终端校验结果(Terminal Verification Results)
VCC	VCC触点上的测量电压(Voltage Measured on VCC Contact)
WI	等待时间整数(Waiting Time Integer)
CCYYMMDD	年、月、日(Year, Month, Day)
‘0’~‘9’ ‘A’~‘F’	16进制数字
[]	可选部分
A:=B	A被赋予B值
A=B	A等于B
$A \equiv B \pmod n$	整数A与B之差模n, 即存在一个整数 d, 使得 $(A-B)=dn$
$A \pmod n$	A模n
Abs(n)	n的绝对值
$Y:=\text{ALG}(K)[X]$	用保密密钥 K, 通过64位块加密方法, 对64位数据块X进行加密
$X:=\text{ALG-1}(K)[Y]$	用保密密钥 K, 通过64位块加密方法, 对64位数据块Y进行解密
$Y:=\text{Sign}(SK)[X]$	用私有密钥SK, 通过使用非对称可逆算法, 对数据块X进行签名
$X=\text{Recover}(PK)[Y]$	用公开密钥SK, 通过使用非对称可逆算法, 对电子签名数据块Y进行恢复
$C:=(A B)$	将m位块B链接到n位块A后, 定义为: $C=2^m A+B$
$H:=\text{Hash}[\text{MSG}]$	用80位的哈希函数对报文MSG哈希运算
Lcm(a,b)	两个整数a和b的最小公倍数
n	整数N的位长
$(X n)$	整数X和整数n($n=pq$, p和q为素数)的Jacobi值, 有如下定义: $J:=(X(p-1)/2 \pmod p)(X(q-1)/2 \pmod q)$ 如果 $J=1$ 或 $j=(pq-p-q+1)$ 则: $(X n)=1$ 否则 $(X n)=-1$ 注: 整数X的Jacobi值在没有n素数因子时, 也可计算
X_x	任意值

5 机电特性、逻辑接口与传输协议

本部分参照采用了ISO 7816第1至第3部分、中国金融集成电路（IC）卡规范第3部分：与借记/贷记应用无关的IC卡与终端接口需求规范，并与EMV4.1—支付系统集成电路卡规范的第1部分等同，此处不再重复描述。

6 数字证书应用流程

6.1 数字证书应用实现构架

数字证书应用整体的实现包括IC卡端、PC端，以及作为两者之间链接的专用读卡终端设备，整体应用的基本构架如下图：

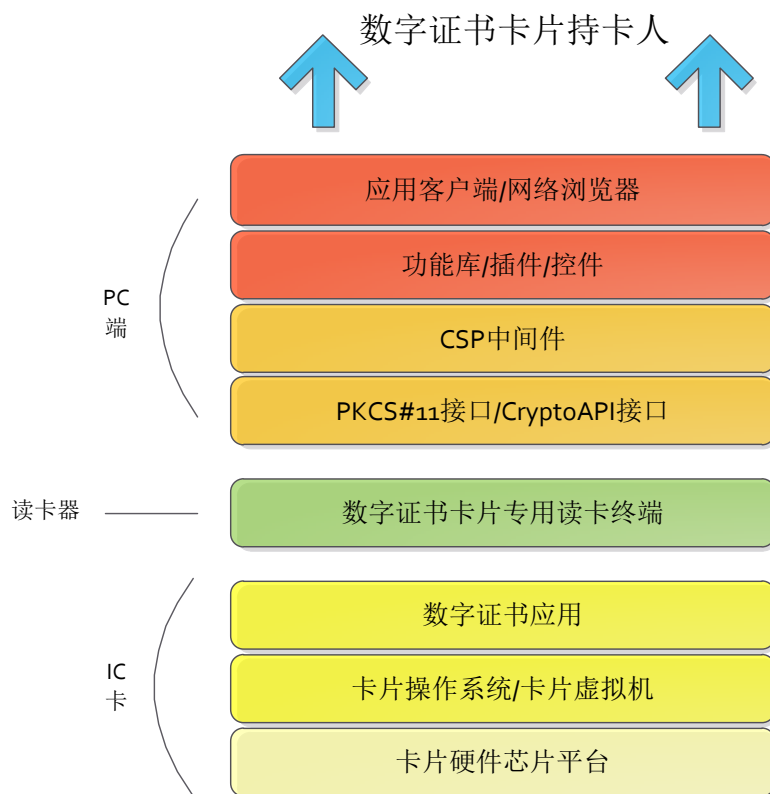


图 6.1 金融 IC 卡数字证书应用基本框架

6.2 数字证书应用流程——证书申请/更新

作为数字证书应用的核心，IC卡对应的数字证书的首次申请并下载，或者是证书到期后的证书更新或证书展期，是证书应用中最重要的一個核心应用环节。通常这个应用流程使用频率较低，通常为一定的时间周期内定期操作一次。

证书申请/更新的基本流程如下图所示：

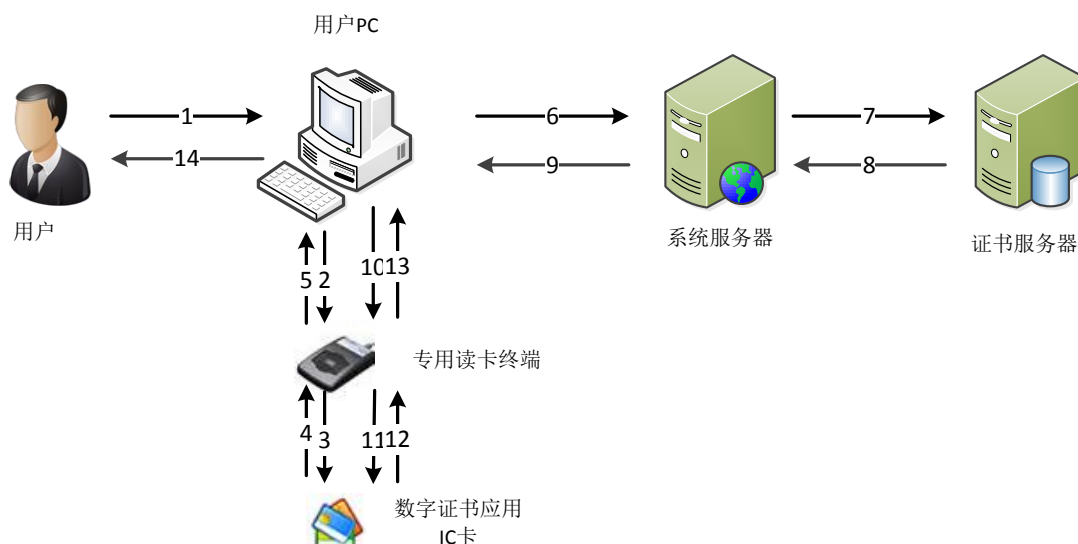


图 6.2 证书申请/更新基本流程

1. 持卡人用户通过PC机上的相关应用程序客户端或者浏览器，发起证书申请/更新交易。证书申请为初次使用数字证书应用IC卡时候进行的第一个交易，后续再对证书进行修改，均为证书更新交易。

2. PC机上的相关应用程序客户端或者浏览器，组织并发送生成公私钥对操作的指令到专用读卡终端，读卡器终端要求用户确认交易，并提示输入数字证书应用用户密码(PIN)。

3. 读卡终端向卡片发送验证 PIN 指令，验证通过后，卡片允许接收生成公私钥对指令。如果验证未通过，卡片返回状态字 63CX (PIN 验证出错，还剩余尝试次数 X 次，X 由发卡方自行设置)。如果验证错误次数超过最大允许次数，卡片返回状态字 6988 (PIN 验证出错次数超限)，PIN 锁定。

4. PIN验证通过后，IC卡生成公私钥对，将公钥返回给专用读卡终端，私钥保留在卡内的安全区。如果是证书更新操作，原密钥直接替换为新密钥。

5. 读卡终端转发公钥数据给PC机上的相关应用程序客户端或者浏览器。

6. PC机上的相关应用程序客户端或者浏览器，按照发卡方指定的格式要求，组织请求签发证书的报文，发送给后台系统服务器。

7. 系统服务器完成相关处理后，转发签发请求到证书服务器。

8. 证书服务器签发生成证书，返回给系统服务器。

9. 系统服务器完成相关处理后，按照发卡方指定格式，将生成的证书发送给PC机上的相关应用程序客户端或者浏览器。PC机上相关应用程序客户端或者浏览器可以选择将证书写入卡片，进行步骤10-13。

10. PC机的上相关应用程序客户端或者浏览器，组织并发送更新记录文件指令，更新的内容为新签发的证书，发送给读卡终端。

11. 读卡终端向卡片转发更新记录文件指令，更新卡片上存储的证书内容，并替换原有证书。

12. IC卡返回更新成功确认。

13. 读卡器终端向PC机上的相关应用程序客户端或者浏览器，转发证书更新成功的确认信息。

14. PC机上的相关应用程序客户端或者浏览器，向持卡人用户显示相关信息，提示证书申请/更新成功完成。

证书申请/更新过程中的异常处理参考银行现有网银申请/更新的异常处理，各行处理方式可能不一致，此处未作统一要求。

6.3 数字证书应用流程——签名和认证

使用数字证书IC卡上存储的私钥对敏感数据进行签名，并在后台通过对应的公钥验证签名后获取明文并进行认证，是证书应用中最主要也是最常用的一种应用模式。通常这个应用流程使用频率较高，涉及身份认证、金融支付交易或者敏感数据传输时都会使用该流程。

只有在完成证书申请后，卡片才能执行签名，否则无法完成签名。

签名和认证的基本流程如下图所示：

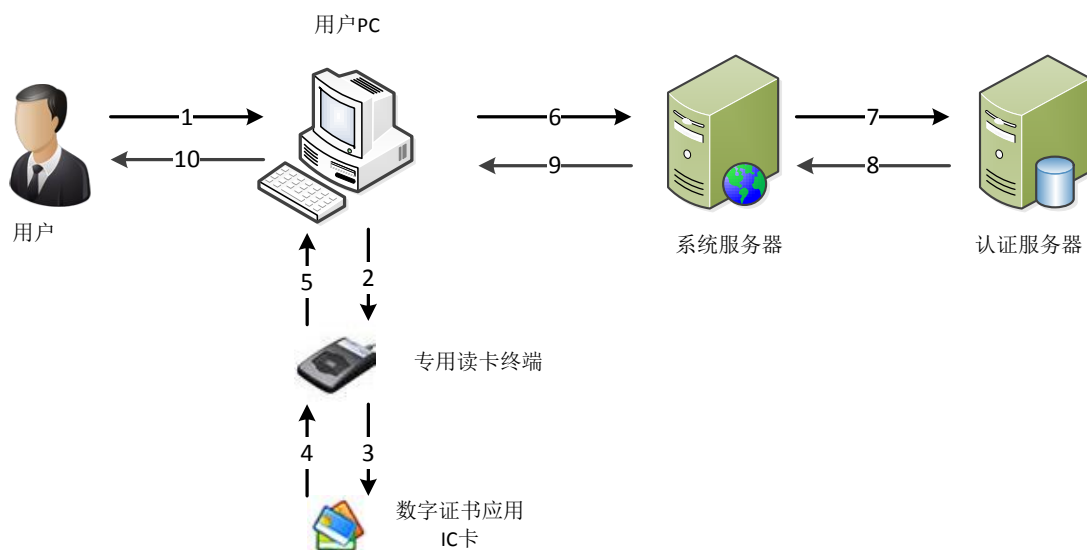


图 6.3 签名认证基本流程

1. 用户通过PC机上的相关应用程序客户端或者浏览器，使用数字证书应用IC卡，进行相关交易。PC机上的相关应用程序客户端或者浏览器，根据内建的交易规则，自动确定是否需要使用数字证书应用IC卡进行签名保护，发起签名和认证交易。

2. PC机上的相关应用程序客户端或者浏览器，组织并发送生成数字签名计算操作的指令到读卡终端，读卡器终端要求用户确认交易。初次签名认证时，PC机上的相关应用程序客户端或者浏览器提示用户需要输入数字证书应用用户密码(PIN)。

3. 初次签名认证时，读卡终端向卡片发送验证PIN指令，验证通过后，卡片允许接收产生数字签名指令。如果验证未通过，卡片返回状态字63CX（PIN验证出错，还剩余尝试次数X次，X由发卡方自行设置）。如果验证错误次数超过最大允许次数，卡片返回状态字6988（PIN验证出错次数超限），PIN锁定。

为了安全起见，卡片再重新上电后需要再次验证PIN，卡片不缓存PIN的安全状态。在未断电情况下，每次进行签名认证时是否需要输入PIN视发卡方要求而定，发卡方可要求只在卡片初次进行签名认证时验证PIN，也可以要求在每次进行签名认证时均需输入PIN。

4. PIN验证通过后，卡片使用卡内存储的指定私钥，对输入的数据进行签名计算，将签名结果返回给读卡终端。

5. 读卡终端转发签名结果给PC机上的相关应用程序客户端或者浏览器。

6. PC机上的相关应用程序客户端或者浏览器，按照发卡方指定的格式，组织交易报文，将签名结果发送给后台系统服务器。

7. 系统服务器完成相关处理后，转发签名结果至证书服务器，请求验证。

8. 证书服务器检索到对应公钥，完成验证，返回验证结果以及被签名的明文数据给系统服务器。

9. 系统服务器完成相关处理后，按照发卡方指定的格式，返回认证结果以及交易处理的返回数据，发送给PC机上的相关应用程序客户端或者浏览器。

10. PC机上的相关应用程序客户端或者浏览器，向持卡人用户显示相关的信息，提示持卡人发起的某个交易成功完成，并显示相关的交易处理返回数据。

以上流程与目前银行网银证书的主流应用流程相符，并非强制性要求，在规范具体实施过程中可根据系统实际状况调整。

7 安全机制

7.1 基本安全要求

7.1.1 共存应用

为了独立地管理一张卡上不同应用间的安全问题，每一个应用应以一个ADF的形式单独存在。亦即在应用之间应设计一道“防火墙”以防止跨过应用进行非法访问。另外，每一个应用也不应该在个人化要求和卡中共存的其他应用规则发生冲突。

7.1.2 密钥的独立性

加密/解密密钥仅用于某种特定功能，不能被任何其他功能所使用，包括保存在 IC 卡中的密钥和用来产生、派生、传输这些密钥的密钥。

7.1.3 密钥和用户密码(PIN)的存放

IC 卡应能够保证用于 RSA 算法/SM2 算法的非对称私有密钥或用于 DES 算法/SM1 算法的对称加密密钥在没有授权的情况下，不会被泄露出来。

使用用户密码（PIN），则应保证其在 IC 卡中的安全存放，且在任何情况下都不会被泄露。

7.1.4 用户密码(PIN)的验证

用户密码（PIN）应采用密文验证方式，即采用用户输入的 PIN 对卡片产生的随机数进行加密，并将加密后的数据送入卡片中，与卡片内 PIN 对相同随机数加密的结果进行比对，验证 PIN 是否一致，详见 Get Challenge、Verify PIN 命令说明。

7.2 安全报文传送

安全报文传送的目的是保证数据的可靠性、完整性和对发送方的认证。数据完整性和对发送方的认证通过使用 MAC 来实现。数据的可靠性通过对数据域的加密来得到保证。

7.2.1 安全报文传送格式

本部分中定义的安全报文传送格式符合 ISO 7816-4 的规定。当 CLA 字节的第二个半字节等于十六进制数字'4'时，表明对发送方命令数据要采用安全报文传送。卡中的 FCI 表明某个命令的数据域的数据是否需要加密传输，是否应该以加密的方式处理。

表 7.1 安全报文传送格式说明

b4	b3	b2	b1	说 明
0	0	x	x	不需要安全报文
0	1	x	x	需要安全报文

7.2.2 报文完整性和验证

MAC 是使用命令的所有元素(包括命令头)产生的。一条命令的完整性,包括命令数据域(如果存在的话)中的数据元,通过安全报文传送得以保证。

7.2.2.1 MAC 的位置

MAC 是命令数据域中最后一个数据元。

7.2.2.2 MAC 的长度

本部分中，MAC 的长度规定为 4 或 8 个字节。

7.2.2.3 MAC 密钥的产生

在安全信息处理过程中用到的 MAC 过程密钥是按照 7.3.4 中描述的过程密钥的产生过程产生的。MAC DEA 密钥的原始密钥用于产生 MAC 过程密钥。

7.2.2.4 MAC 的计算

按照如下的方式使用单重或三重 DEA 加密方式产生 MAC：

第一步：取 8 个字节的 16 进制数字'0'作为初始变量。

第二步：按照顺序将以下数据连接在一起形成数据块：

第三步：将该数据块分成8字节为单位的数据块，标号为D1，D2，D3，D4等。最后的数据块有可能是1-8个字节。

第四步：如果最后的数据块长度是 8 字节的话，则在其后加上 16 进制数字‘80 00 00 00 00 00 00 00’，转到第五步。

如果最后的数据块长度不足 8 字节，则在其后加上 16 进制数字'80'，如果达到 8 字节长度，则转入第五步；否则在其后加入 16 进制数字'0'直到长度达到 8 字节。

第五步：对这些数据块使用 MAC 过程密钥进行加密，过程密钥按照 7.3.2.3 描述的方式产生。如果安全报文传送支持单长度的 MAC DEA 密钥，则依照下图的方式使用 MAC 过程密钥来产生 MAC(根据在第二步中产生的数据块长度的不同，有可能在计算中会多于或少于四步)。

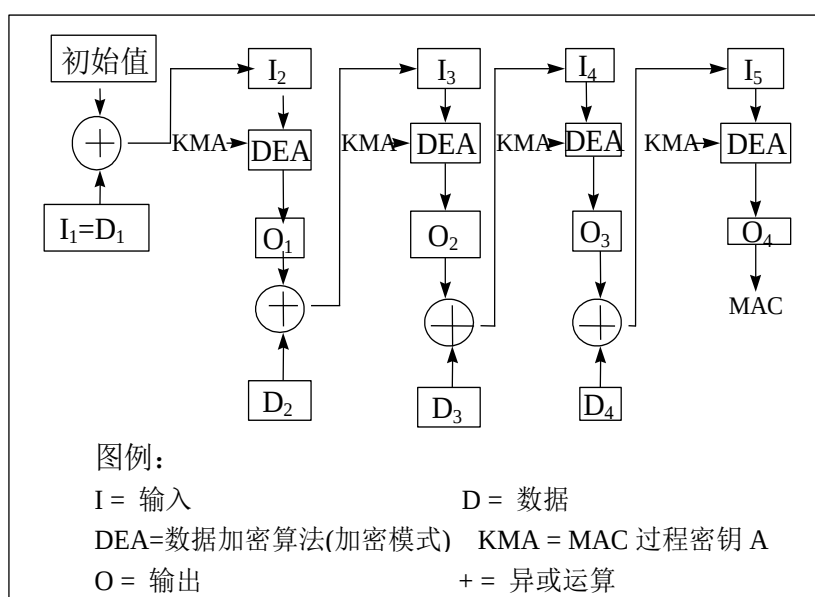


图 7.1 单长度 DEA 密钥的 MAC 算法

如果安全报文传送的处理支持双长度 MAC DEA 密钥, 则使用 MAC 过程密钥 A 和 B(MAC 的产生如下图所示), (根据第二步产生的数据块的长度, 计算过程有可能多于或少于四步)。

¹ Lc 表示命令数据域后面 4 个字节 MAC 数据的长度，例如：APPLICATION BLOCK 命令需要产生一个 MAC，计算 MAC 的 Lc 的输入值是 4-FE，而不是 0，CLA 包括安全报文的表明('X4')。

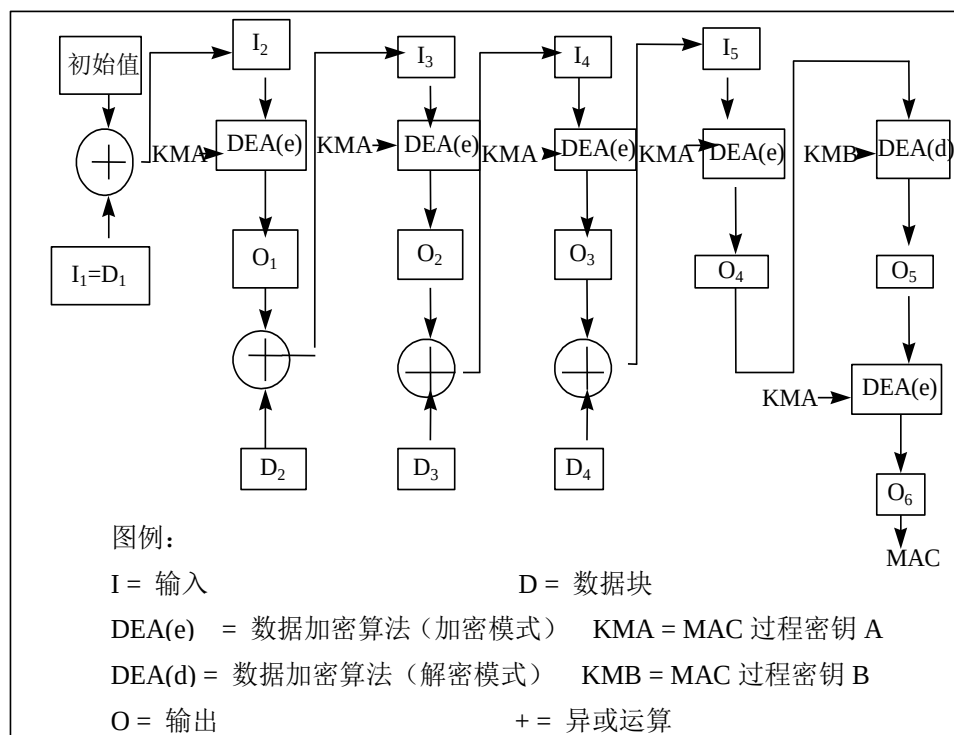


图 7.2 双长度 DEA Key 的 MAC 算法

第六步：最终得到是从计算结果左侧取得的 4 字节长度的 MAC。

7.2.3 数据可靠性

为保证命令中明文数据的保密性，可以将数据加密。所使用的数据加密技术，应被命令发送方和当前卡中被选择的应用所了解。

7.2.3.1 数据加密密钥的计算

在安全报文处理过程中用到的数据，加密过程密钥按照 7.3.4 中描述的方式产生。数据加密过程密钥的产生过程是从卡中的数据加密 DEA 密钥开始的。

7.2.3.2 被加密数据的结构

当命令中要求的明文数据需要加密时，它先要被格式化为以下形式的数据块：

- 明文数据的长度，不包括填充字符(LD)
- 明文数据
- 填充字符(根据 7.3.3.3 的要求)

然后整个数据块使用 7.3.3.3 中描述的数据加密技术进行加密。

7.2.3.3 数据加密计算

数据加密技术如下所述:

第一步：用 L_D 表示明文数据的长度，在明文数据前加上 L_D 产生新的数据块。

第二步：将第一步中生成的数据块分解成 8 字节数据块，标号为 D1, D2, D3, D4 等等。最后一个数据块长度有可能不足 8 位。

第三步：如果最后(或唯一)的数据块长度等于 8 字节，转入第四步；如果不足 8 字节，在右边添加 16 进制数字'80'。如果长度已达 8 字节，转入第四步；否则，在其右边添加 1 字节 16 进制数字'0'直到长

度达到 8 字节。

第四步：每一个数据块使用 7.3.3.1 中描述的数据加密方式加密。

如果采用单长度数据加密 DEA 密钥，数据块的加密如下图所示(使用数据加密过程密钥 A 进行加密)。

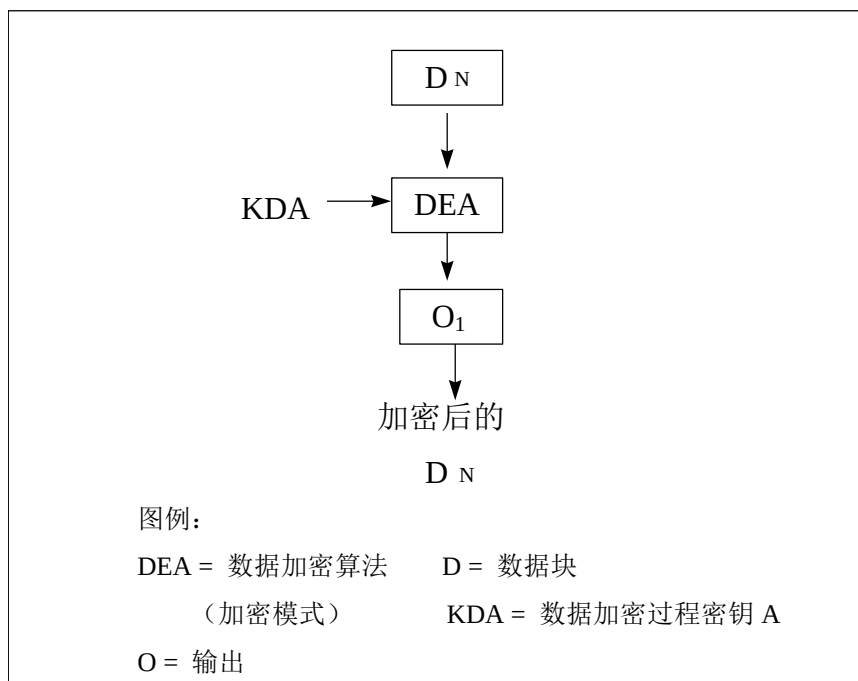


图 7.3 单长度 DEA 密钥的数据加密

如果采用双长度数据加密 DEA 密钥，则数据块的加密如下图所示(使用数据加密过程密钥 A 和 B 来进行加密)。

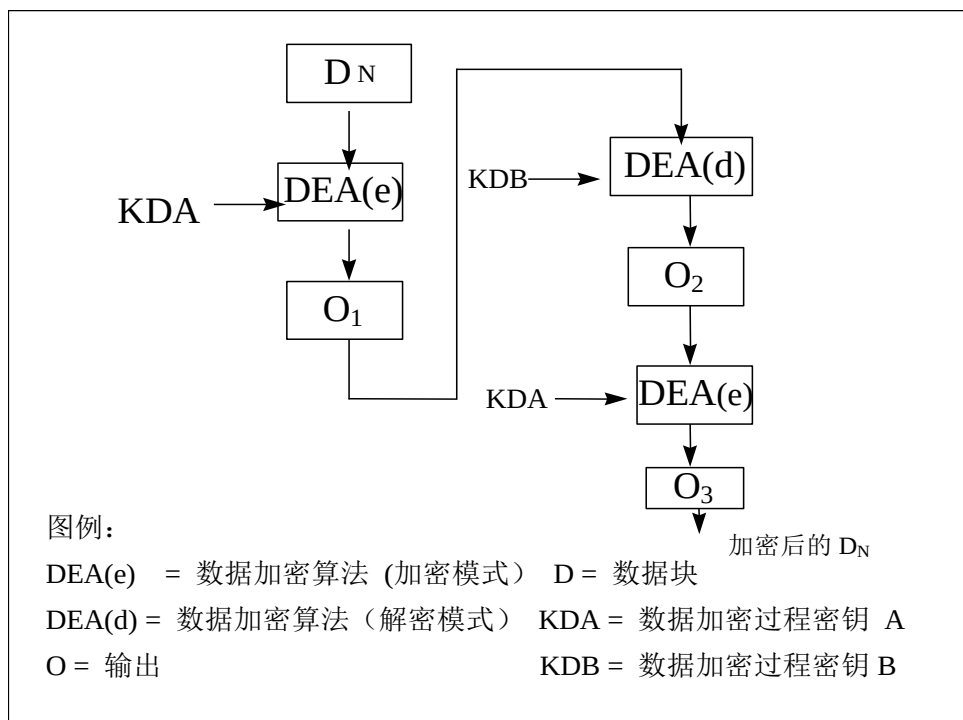


图 7.4 使用双长度 DEA 密钥的数据加密

第五步：计算结束后，所有加密后的数据块依照原顺序连接在一起(加密后的 D1，加密后的 D2，等

等)。并将结果数据块插入到命令数据域中。

7.2.3.4 数据解密计算

卡片接收到命令之后，需要将包含在命令中的加密数据进行解密。数据解密的技术如下：

第一步：将命令数据域中的数据块分解成 8 字节长的数据块，标号为 D1，D2，D3，D4 等等。每个数据块使用如 7.3.3.1 所描述的方法产生的数据加密过程密钥进行解密。

如果采用单长度数据加密的 DEA 密钥，数据块解密如图 5 所示(使用数据加密过程密钥 A 进行解密)。

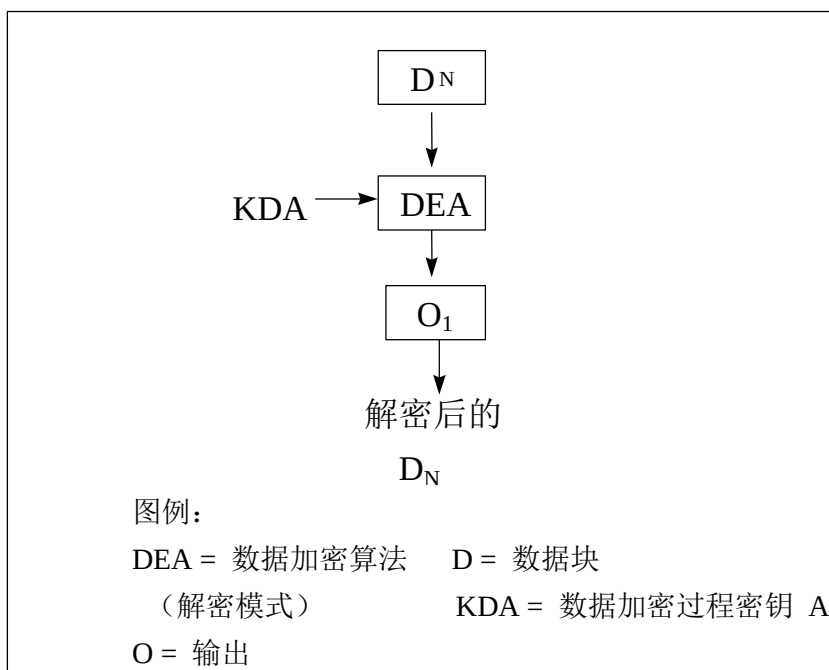


图 7.5 使用单长度 DEA 密钥的数据解密

如果采用双长度数据加密的 DEA 密钥，则数据块的解密如下图所示(使用数据加密过程密钥 A 和 B 来进行解密)。

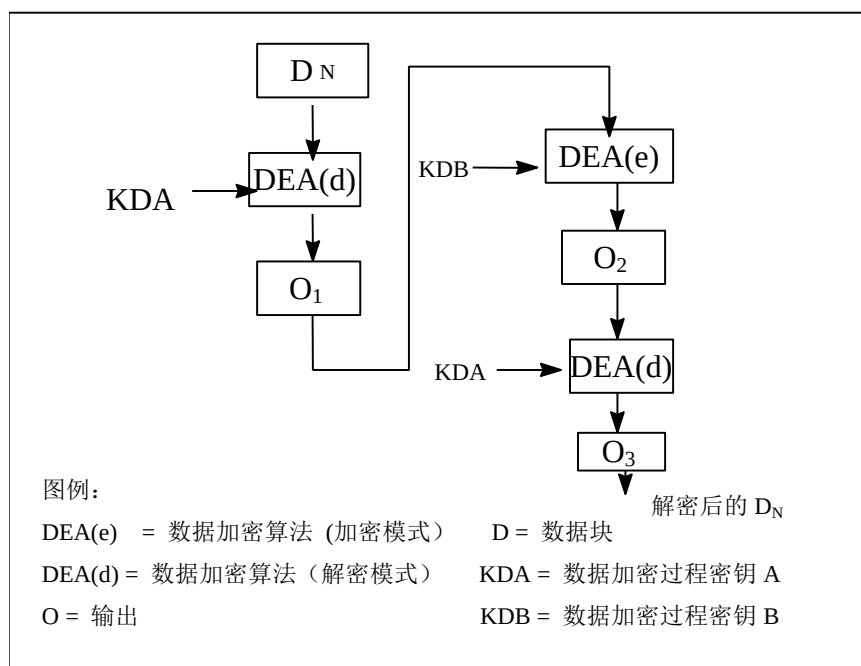


图 7.6 使用双长度 DEA 密钥的数据解密

第二步：计算结束后，所有解密后的数据块依照顺序(解密后的 D1，解密后的 D2，等等)链接在一起。数据块由 LD、明文数据、填充字符(如果在 7.3.3.3 描述的加密过程中增加的话)组成。

第三步：因为 LD 表示明文数据的长度，因此，它被用来恢复明文数据。

7.2.4 安全报文传送的命令情况

在 GB/T 16649.4 中定义了四种命令情况。本节简单的讨论这些情况对命令 APDU 的作用。

情况一：这种情况时，没有数据送到 ICC(Lc)中，也没有数据从卡中返回(Le)。没有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2
-----	-----	----	----

有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	MAC
-----	-----	----	----	----	-----

CLA 的第二个半字节是'4'表明支持第二种情况的安全报文传送技术。Lc 为 MAC 的长度。

情况二：这种情况时，命令中没有数据送到卡中，但有数据从卡中返回。没有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Le
-----	-----	----	----	----

有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	MAC	Le
-----	-----	----	----	----	-----	----

CLA 的第二个半字节是'4'表明支持第二种情况的安全报文传送技术。Lc 为 MAC 的长度。

情况三：这种情况时，命令中有数据传送到卡中，但没有数据从卡中返回。没有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	命令数据
-----	-----	----	----	----	------

有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	命令数据	MAC
-----	-----	----	----	----	------	-----

CLA 的第二个半字节是'4'表明支持第二种情况的安全报文传送技术。Lc 为命令数据加上 MAC 的长度。

情况四：这种情况时，在命令中有数据送到卡中，也有数据从卡中返回。没有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	命令数据	Le
-----	-----	----	----	----	------	----

有安全报文传送要求的命令情况如下：

CLA	INS	P1	P2	Lc	命令数据	MAC	Le
-----	-----	----	----	----	------	-----	----

CLA 的第二个半字节是'4'表明支持第二种情况的安全报文传送技术。Lc 为命令数据加上 MAC 的长度。

7.3 认可的加密算法

本部分主要描述数字证书应用卡片认可的加密算法，并非强制要求卡片支持本部分所述全部算法。

7.3.1 对称算法(DES)

安全报文允许使用 64 位块加密算法，该算法在 ISO 8731-1、ISO 8732、ISO/IEC 10116 中定义。以下定义的单 DES 加密和 3-DES 加密版本都可以用在第三节中描述的加密运算和 MAC 机制中。

3-DES 加密是指使用双长度(16 字节)密钥 $K=(K_L||K_R)$ 将 8 字节明文数据块加密成密文数据块，如下所示：

$$Y = \text{DES}(K_L)[\text{DES}^{-1}(K_R)[\text{DES}(K_L)[X]]]$$

解密的方式如下：

$$X = \text{DES}^{-1}(K_L)[\text{DES}(K_R)[\text{DES}^{-1}(K_L)[Y]]]$$

7.3.2 非对称算法(RSA)

RSA 算法被用来进行静态和动态数据验证以及数字签名。公开密钥的指数可以为奇数，也可以为偶数。

算法产生的数字签名的长度等于所用的模数的大小。模数的最大限制如表 1 所示：

表 7.2 不同模数在字节上的最大限制

描 述	最大长度
数字证书应用发卡方公开密钥模数	256字节
数字证书应用IC卡公开密钥模数	256字节

同时，数字证书应用发卡方公开密钥模数的长度 N_I ，数字证书应用 IC 卡公开密钥模数的长度 N_{IC} 应该满足以下关系： $N_{IC} < N_I$ 。

在选择公开密钥模数的长度时，应该考虑到密钥的生命周期以及在此生命周期内被解密的可能性。每个密钥的长度范围(上、下限)在其相应的专用规范中规定。

发卡方公开密钥的指数的长度与 IC 卡公开密钥的指数长度由数字证书应用发卡方决定。指数可以是预先约定的固定的数字如 3 或 65537。

RSA 算法的密钥、签名和恢复功能在下面说明。公开密钥的奇偶指数将分别考虑。同时，也规定了密钥产生过程的最低要求。

7.3.2.1 奇数公开密钥指数

7.3.2.1.1 密钥

带有奇数公开密钥指数 e 的 RSA 数字签名机制的私有密钥 S_K 包括两个素数 p 和 q , $p-1$ 和 $q-1$ 与 e 是互素的, 它们与私有密钥指数 d 存在如下关系:

$$ed \equiv 1 \pmod{(p-1)(q-1)}$$

相对应的公开密钥 P_K 包括公开密钥模数 $n=pq$ 和公开密钥指数 e 。

7.3.2.1.2 签名功能

带有奇数公开密钥指数的 RSA 的签名功能定义如下:

$$S = \text{Sign}(S_K)[X]: = X^d \pmod{n}, \quad 0 < X < n,$$

X 是要签名的数据, S 是相对应的数字签名。

7.3.2.1.3 恢复功能

带有奇数公开密钥指数的 RSA 的恢复功能定义如下:

$$X = \text{Recover}(P_K)[S]: = S^e \pmod{n}.$$

7.3.2.2 密钥的产生

对 RSA 密钥对的主要要求是保证模数是一个素数, 即是一个不能通过有效的有特殊目的的因数分解算法分解的整数。

7.3.3 安全哈希算法(SHA-1)

这个算法在 FIPS 180¹² 中被标准化。SHA-1 中输入任意长度的信息, 产生一个 20 字节的哈希值。

7.3.4 对称算法 (SM1)

国产分组加密算法。

7.3.5 非对称算法 (SM2)

国产非对称算法。

7.3.6 摘要算法 (SM3)

国产摘要算法。SM3 中输入任意长度的信息, 产生一个 32 字节的摘要值。

8 命令

8.1 C-APDU 格式

C-APDU 由 4 字节长的必备头后跟一个可变长的条件体组成, 见下图:

CLA	INS	P1	P2	Lc	Data	Le
←必备头→				←条件体→		

C-APDU 中发送的数据字节数用 L_c (命令数据域的长度)表示。

R-APDU 中期望返回的数据字节数用 L_e (期望数据长度)表示。当 L_e 存在且值为 0 时, 表示需要最大字节数(256 字节)。在命令报文需要时, L_e 始终被设为'00'。

C-APDU 报文的内容见下表:

代码	描 述	长度
CLA	命令类别	1
INS	指令代码	1
P1	指令参数 1	1
P2	指令参数 2	1

¹² SHA-1 的标准见 ISO/IEC CD 10118-3。

Lc	命令数据域中存在的字节数	0 或 1
Data	命令发送的数据位串(=Lc)	可变
Le	响应数据域中期望的最大数据字节数	0 或 1

8.2 R-APDU 格式

R-APDU 格式由一个变长的条件体和后随两字节长的必备尾组成，见下图：

Data	SW1	SW2
←条件体→	←尾→	

R-APDU 报文的内容见下表：

代码	描 述	长度
Data	响应中接收的数据位串(=Lr)	变长
SW1	命令处理状态	1
SW2	命令处理限定	1

当使用 T=1 协议时,对于所有 Le='00' 的命令, 状态码 SW1 SW2 = '90 00' 或 '61 La' 均表示命令的成功执行。但由于可读性的需要, 在整篇文章中这两种应答码只用了'90 00' 作为参考。

本节描述了以下的命令—响应 APDU:

- CREATE FILE(创建文件)
- COMPUTE DIGITAL SIGNATURE(数字签名)
- COMPUTE HASH (HASH 计算)
- ENCIPHER/DECIPHER(加/解密计算)
- VERIFY PIN(PIN 验证)
- GET CHALLENGE(取随机数)
- GENERATE ASYMMETRIC KEY (生成公私钥对)
- MANAGE SECURITY ENVIRONMENT(安全环境设置)
- PERFORM SECURITY OPERATION (安全操作)
- READ BINARY(读取二进制文件)
- READ RECORD(读取记录文件)
- UPDATE BINARY(更新二进制文件)
- UPDATE RECORD(更新记录文件)
- VERIFY SIGNATURE (签名验证)
- WRITE PIN(装载或更新 PIN)

8.3 Create File (创建文件)

8.3.1 定义和范围

Create 命令用于在数字证书应用中创建一个数据文件, 可以支持创建二进制文件或记录文件。Create File 命令在卡片中分配文件所需的空问, 文件所需要的空问在该命令数据与中指明。

对于变长记录文件, 本命令只指明所需要的空问的总大小, 并不指明各记录的长度。各记录的具体长度由第一次使用的 Update Record 命令决定。

文件创建后, 默认数据以 0x00 填充。

8.3.2 命令报文

代码	值
CLA	'80'
INS	'E2'
P1	'00'
P2	'00'~'04'
Lc	'07'
Data	

Le	不存在
----	-----

P1 字节的解析如下：

P1='00'表示创建二进制文件；

P1='01'表示创建定长记录文件；

P1='02'表示循环记录文件；

P1='03'表示创建变长记录文件；

P1='04'表示创建特殊的变长记录文件，用于创建私钥数据文件或公钥数据文件。

8.3.3 命令报文数据域

命令报文数据域包含以下内容：

字节	数据元	长度
1-2	文件标识符（FID）	2
3	读权限（'00'表示自由明文写、'01'表示需要验证PIN）	1
4	写权限（编码同上）	1
5	短文件标识符（1-31）	1
6-7	文件大小（二进制或变长记录文件：2字节文件大小； 定长记录文件或循环记录文件：1字节记录数+1字节记录长度）	2

8.3.4 响应报文数据域

响应报文数据域不存在。

8.3.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
'6581'	内存失败
'6700'	长度出错
'6982'	安全条件不满足
'6985'	使用条件不满足
'6A80'	数据结构不正确
'6A81'	功能不支持
'6A84'	空间不足

8.4 Compute Digital Signature（数字签名计算）

8.4.1 定义和范围

Compute Digital Signature 命令是 Perform Security Operation 命令的子命令。该命令用于对一个 HASH 值进行签名计算，这个 HASH 值由卡片通过 Compute HASH 命令计算得到。也就是说，执行 Compute Digital Signature 命令前，卡片中必须存在一个有效的 HASH 值。

执行该命令前，必须先成功执行 Manage Security Environment 命令，指定数字签名计算的私钥 ID 和 Alg-ID（即指定填充方式）。

8.4.2 命令报文

代码	值
CLA	'00'
INS	'2A'
P1	'9E'
P2	'9A'
Lc	不存在
Data	不存在
Le	'00' / '签名数据长度'

8.4.3 命令报文数据域

命令报文数据域不存在

8.4.4 响应报文数据域

响应报文数据域返回签名数据。

8.4.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足
‘6E01’	命令顺序无效
‘6E02’	无安全环境或安全环境无效

8.5 Compute HASH（HASH 计算）

8.5.1 定义和范围

Compute HASH 命令是将命令输入的数据通过指定的 HASH 算法计算成一个 HASH 值。

通过一个或多个 Compute HASH 命令计算的 HASH 值存储在 EEPROM 中，留待后续的 Compute Digital Signature 命令或 Verify Signature 命令使用。

待计算的数据被分成多个 64 字节为单位的数据块，其中，最后一个数据块可以少于 64 字节。每个数据块通过一条 Compute HASH 命令送入卡片。

8.5.2 命令报文

代码	值
CLA	‘00’/‘01’ 其中，‘00’表示当前命令是最后一条 HASH 计算命令； ‘01’表示当前命令不是最后一条 HASH 计算命令
INS	‘2A’
P1	‘90’
P2	‘80’/‘A0’ 其中，‘80’表示 HASH 的计算全部由卡片完成， ‘A0’表示 HASH 的计算由卡片和终端共同完成
Lc	待计算数据的长度
Data	待计算的数据
Le	不存在或 HASH 值

8.5.3 命令报文数据域

命令报文数据域包含待计算的数据。

当终端只对部分待计算数据进行 HASH 计算时：

DATA = ‘91’ || ‘1C’ || 中间HASH值 || Counter || ‘81’ || L || 剩余的待计算数据；

其中，中间HASH值和Counter由终端用计算得到，Counter共8字节，表示已经被计算的输入数据的位数。

若终端完全不参与HASH计算时，‘91’ || ‘1C’ || 中间HASH值 || Counter部分可以省略，即可由卡片直接计算HASH值。

当终端对所有待计算数据进行HASH计算时：

DATA = ‘91’ || ‘14’ || 最终HASH值（采用SHA-1, RIPEMD-160算法计算，由终端计算）；
或DATA = ‘91’ || ‘20’ || 最终HASH值（采用SM3算法计算，由终端计算）。

8.5.4 响应报文数据域

若当前命令不是最后一条HASH计算命令，则响应报文不存在；

若当前命令是最后一条HASH计算命令，则响应报文为计算得到的HASH值。

8.5.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足
‘6E01’	命令顺序无效
‘6E02’	无安全环境或安全环境无效

8.6 Encipher/Decipher（加/解密）

8.6.1 定义和范围

Encipher/Decipher 命令是 Perform Security Operation 命令的子命令，用于加密或解密数据。

该命令执行前，必须先成功执行 Manage Security Environment 命令，指定进行加密的公钥或进行解密的私钥，且被指定的密钥必须具有相应加/解密功能。

当命令用于加密模式时，P1=‘86’,P2=‘80’；

当命令用于解密模式时，P1=‘80’,P2=‘86’。

8.6.2 命令报文

代码	值
CLA	‘00’
INS	‘2A’
P1	‘80’/‘86’
P2	‘80’/‘86’
Lc	待加/解密数据的长度
Data	待加/解密的数据
Le	‘00’

8.6.3 命令报文数据域

命令报文数据域包含待加/解密的数据

8.6.4 响应报文数据域

当命令为加密模式时，响应报文数据域包含PI(填充标志，‘00’)和密文数据；

当命令为解密模式时，响应报文数据域包含解密后的明文数据。

8.6.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败

‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足
‘6E01’	命令顺序无效
‘6E02’	无安全环境或安全环境无效

8.7 Verify PIN (PIN 验证)

8.7.1 定义和范围

Verify PIN 命令要求卡片中的应用验证外部输入的密码 (PIN)。

执行该命令前, 需要先执行 Get Challenge 命令, 获取 8 字节的随机数。

8.7.2 命令报文

代码	值
CLA	‘00’
INS	‘82’
P1	‘00’/‘01’ ‘00’表示使用 DES 算法计算认证数据; ‘01’表示使用 SM1 算法计算认证数据;
P2	‘00’
Lc	‘08’
Data	认证数据
Le	不存在

8.7.3 命令报文数据域

命令报文数据域包含认证数据。认证数据由用户输入的密码 (PIN) 对 Get Challenge 命令返回的随机数, 按照 P1 指定的加密算法计算得到的密文结果。用户密码 (PIN) 的长度限制为 4 字节~8 字节, 如果用户密码 (PIN) 的长度小于 8 字节, 采用右补 ‘FF’ 的方式, 填充至 8 字节长度。

8.7.4 响应报文数据域

响应报文数据域不存在。

8.7.5 响应报文状态码

此命令执行成功的状态码为 ‘9000’。

IC 卡可能回送的警告状态码如下表所示:

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘63CX’	PIN 验证出错, 还剩余尝试次数 X 次
‘6988’	PIN 验证出错次数超限, PIN 锁定

8.8 Get Challenge (取随机数)

8.8.1 定义和范围

Get Challenge 命令用于向卡片请求一个用于安全过程的随机数。

该随机数只能用于下一条指令, 无论下一条命令是否使用了该随机数, 该随机数都将立即失效。

8.8.2 命令报文

代码	值
CLA	'00'
INS	'84'
P1	'00'
P2	'00'
Lc	不存在
Data	不存在
Le	'04'/'08'

8.8.3 命令报文数据域

命令报文数据域不存在。

8.8.4 响应报文数据域

响应报文数据域包括随机数，长度为4或8字节。

8.8.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
'6581'	内存失败
'6700'	长度出错
'6982'	安全条件不满足
'6985'	使用条件不满足
'6A80'	数据结构不正确
'6A81'	功能不支持

8.9 Generate Asymmetric Key(生成公私钥对)

8.9.1 定义和范围

Generate Asymmetric Key命令用于产生一个完整的非对称密钥公私钥对，对于RSA算法，该密钥包含以下密钥分量：素数 p 和 q ， $1/e \bmod (p-1)$ ， $1/e \bmod (q-1)$ ， $1/q \bmod p$ ；对于SM2算法，该密钥包含算法规定的几个密钥分量。密钥分量将存储在相应的密钥文件中，具体的密钥记录由P2指定的KID决定。产生的密钥对的公钥值，在响应报文中返回。

产生的密钥长度由命令数据域指定，密钥长度要求在64~256字节范围内，且必须是8的整数倍；

在使用该命令同时装载私钥和公钥前，必须保证相应的私钥头和公钥头部分已经通过 Update Record 命令分别装载到相应的密钥文件中；且公钥的 KID 和私钥的 KID 必须保持一致。

8.9.2 命令报文

代码	值
CLA	'00'
INS	'47'
P1	'00'/'01' 其中，'00'表示产生 RSA 公私钥对，其公钥指数为'010001' '01'表示产生 RSA 公私钥对，其公钥指数为'03' '10'表示产生 SM2 公私钥对
P2	KID
Lc	'02'
Data	2字节的密钥长度（以 bit 为单位）
Le	'00'

8.9.3 命令报文数据域

命令报文数据域包含两字节的密钥长度，用于指定该命令产生的非对称公私钥对的长度

8.9.4 响应报文数据域

响应报文数据域包含产生的RSA公钥模。其结构如下表：

标志	长度（字节）	值	存在方式
‘6E’	公钥值长度	公钥值	M

8.9.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足

8.10 Manage Security Environment（安全环境管理）

8.10.1 定义和范围

Manage Security Environment 命令用于为所有安全操作命令指定相应的数据参数，如指定参加签名、加/解密等的公钥/私钥、指定数字签名等的算法等等。

若命令数据域中指定了一个私钥，则卡片需要先验证如下信息：

1. 相应的密钥文件中是否存在由 SKID 指定的 RSA/SM2 私钥；
2. 该密钥是否允许被 Compute Signature 或 Encipher/Decipher 命令使用；

若命令数据域中指定了一个公钥，则卡片需要先验证如下信息；

1. 相应的密钥文件中是否存在由 PKID 指定的公钥；
2. 是否允许被 Verify Signature 命令、Encipher/Decipher 命令使用；

一个安全设置过程，只能使用一次 Manage Security Environment 命令。

该命令指定公钥/私钥后，后续相关的安全操作命令将根据密钥头中的算法标识字节指定的算法类型决定使用 RSA 算法或 SM2 国产算法。

8.10.2 命令报文

代码	值
CLA	‘00’
INS	‘33’
P1	
P2	
Lc	后续数据长度
Data	TLV 数据对象
Le	不存在

P1P2 可以有如下组合：

P1	P2	TLV 数据对象对应的命令
‘42’	‘A6’	Verify Signature 命令
‘42’	‘A8’	Encipher/Decipher 命令（加密模式）
‘82’	‘A6’	Compute Signature 命令
‘82’	‘A8’	Encipher/Decipher 命令（解密模式）

8.10.3 命令报文数据域

命令数据域根据对应的后续命令，由一个或多个TLV结构组成。

各TLV结构如下表：

类型	T	L	V
私钥KID	‘80’	‘01’	SKID
公钥KID	‘81’	‘01’	PKID
摘要算法ID	‘82’	‘01’	Alg-ID

与Compute Signature命令有关的命令对应的Alg-ID的编码及意义如下表所示：

Alg-ID	HASH算法	填充方式	ASN.1-OID
‘11’	SHA-1	根据DIN V66291-1指定填充方式填充	
‘12’	SHA-1	根据PKCS#1 块类型01方式填充	{1 3 14 3 2 26}(OIW)
‘21’	RIPEMD-160	根据 DIN V66291-1 指定填充方式填充	
‘22’	RIPEMD-160	根据 PKCS#1 块类型 01 方式填充	{1 3 36 3 2 1} (TeleTrust)
‘32’	MD-5	根据 PKCS#1 块类型 01 方式填充	{1 2 840 113549 2 5} (RSADSI)
‘42’	SM3		

Alg-ID = ‘11’是标准的HASH算法和填充方式，若没有指定Alg-ID，将使用标准的HASH算法和填充方式。

与Encipher/Decipher命令有关的命令对应的Alg-ID的编码及意义如下表所示：

Alg-ID	HASH算法	填充方式
‘02’	SHA-1	根据PKCS#1 块类型02方式填充
‘03’	SHA-1	无填充
‘04’	SM3	

8.10.4 响应报文数据域

响应报文数据域不存在

8.10.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足
‘6E01’	命令顺序无效
‘6E02’	无安全环境或安全环境无效

8.11 Perform Security Operation(安全操作)

Perform Security Operation命令包含以下子命令：

1. Compute Digital Signature命令
2. Compute HASH命令
3. Encipher/Decipher命令
4. Verify Certification命令
5. Verify Signature命令

所有子命令的INS字节均为'2A'。

8.12 Read Binary（读取二进制文件）

8.12.1 定义和范围

Read Binary 命令用于读取二进制文件的内容（或部分内容）。

8.12.2 命令报文

代码	值
CLA	'00'
INS	'B0'
P1	见下表编码
P2	从文件中读取的第一个字节的偏移地址
Lc	不存在
Data	不存在
Le	'00'

P1 参数编码如下：

b8	b7	b6	b5	b4	b3	b2	b1	含 义
1	0	0						RFU
			X	X	X	X	X	SFI

8.12.3 命令报文数据域

命令报文数据域不存在。

8.12.4 响应报文数据域

当Le的值为零时，只要文件的最大长度在256（短长度）或65536（扩展长度）之内，则其全部字节将被读出。

8.12.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
'6581'	内存失败
'6700'	长度出错
'6982'	安全条件不满足
'6985'	使用条件不满足
'6A80'	数据结构不正确
'6A81'	功能不支持
'6A84'	空间不足

8.13 Read Record（读取记录文件）

8.13.1 定义和范围

Read Record 命令用于读取记录文件的内容。

8.13.2 命令报文

代码	值
CLA	'00'
INS	'B2'
P1	记录的个数
P2	见下表
Lc	不存在或 5 字节
Data	不存在
Le	不存在

P2 参数编码如下:

b8	b7	b6	b5	b4	b3	b2	b1	含 义
X	X	X	X	X				SFI
					1	0	0	记录号在P1中给出

8.13.3 命令报文数据域

命令报文数据域不存在。

8.13.4 响应报文数据域

响应报文数据域不存在

8.13.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示:

状态码	含义
'6581'	内存失败
'6700'	长度出错
'6982'	安全条件不满足
'6985'	使用条件不满足
'6A80'	数据结构不正确
'6A81'	功能不支持
'6A84'	空间不足

8.14 Update Binary (更新二进制文件)

8.14.1 定义和范围

Update Binary 命令使用命令数据域中的数据修改 EF 文件中已有的数据。

8.14.2 命令报文

代码	值
CLA	'00'
INS	'D6'
P1	见下表编码
P2	要修改的第一个字节的偏移地址
Lc	后续数据长度
Data	修改用的数据
Le	不存在

P1 参数编码如下:

b8	b7	b6	b5	b4	b3	b2	b1	含 义
1	0	0						RFU
			X	X	X	X	X	SFI

8.14.3 命令报文数据域

命令报文数据域包括修改用数据

8.14.4 响应报文数据域

响应报文数据域不存在

8.14.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示:

状态码	含义
'6581'	内存失败

‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足

8.15 Update Record（更新记录文件）

8.15.1 定义和范围

Update Record 命令用命令数据域中给定的数据更改指定的记录。

8.15.2 命令报文

代码	值
CLA	‘00’
INS	‘DC’
P1	‘00’表示当前记录/其他值表示指定的记录号
P2	见下表
Lc	后续数据长度
Data	更新原有记录的新记录
Le	不存在

P2 参数编码如下：

b8	b7	b6	b5	b4	b3	b2	b1	含 义
X	X	X	X	X				SFI
					0	0	0	第一个记录
					0	0	1	最后一个记录
					0	1	0	下一个记录
					0	1	1	上一个记录
					1	0	0	记录号在P1中给出
其余值								RFU

8.15.3 命令报文数据域

命令报文数据域包括更新原有记录的新记录

8.15.4 响应报文数据域

响应报文数据域不存在

8.15.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足

8.16 Verify Signature（签名验证）

8.16.1 定义和范围

Verify Signature 命令是 Perform Security Operation 命令的子命令。该命令用于卡片对终端输入的签名进行验证。卡片进行签名验证操作前，必须满足以下条件：

1. 卡片中存在 HASH 值；
2. 签名的长度在 64 字节和 256 字节范围内；
3. 存在相应的公钥；

执行该命令前，必须先成功执行 Manage Security Environment 命令，指定进行签名验证的公钥 ID 和 Alg-ID；

8.16.2 命令报文

代码	值
CLA	‘00’
INS	‘2A’
P1	‘00’
P2	‘A8’
Lc	待验证数据的长度
Data	待验证的签名数据
Le	不存在

8.16.3 命令报文数据域

命令报文数据域包含待验证的签名数据。

8.16.4 响应报文数据域

响应报文数据域不存在

8.16.5 响应报文状态码

此命令执行成功的状态码为‘9000’。

IC卡可能回送的警告状态码如下表所示：

状态码	含义
‘6581’	内存失败
‘6700’	长度出错
‘6982’	安全条件不满足
‘6985’	使用条件不满足
‘6A80’	数据结构不正确
‘6A81’	功能不支持
‘6A84’	空间不足
‘6E01’	命令顺序无效
‘6E02’	无安全环境或安全环境无效

8.17 Write PIN(装载或更新 PIN)

8.17.1 定义和范围

Write PIN 命令用于装载或更新 PIN。

该命令用于更新 PIN 时，命令数据域由旧 PIN 值对新 PIN 值做对称加密运算得到。

8.17.2 命令报文

代码	值
CLA	‘80’
INS	‘F4’
P1	‘00’/‘01’ ‘00’表示装载 PIN；‘01’表示更新已有的 PIN 值
P2	‘00’/‘01’ 当 P1=‘00’时，P2=‘00’表示使用 DES 算法 8 字节 PIN；P2=‘01’表示使用 SM1

	算法 16 字节 PIN; 当 P1='01'时, P2='00'表示使用 DES 算法做加密计算; P2='01'表示使用 SM1 算法做加密计算。
Lc	'0A'/'12'/'10'/'20'
Data	PIN 值/加密后的 PIN 信息
Le	不存在

8.17.3 命令报文数据域

命令报文数据域包含PIN值。

如果P1 = '00', 装载新PIN, 命令报文数据域如下格式:

PIN尝试次数上限	PIN尝试次数初始值	PIN明文值 (8/16字节)
'XX'	'XX'	实际PIN长度不足8/16字节, 以'FF'右填充

如果P1 = '01', 更新已有的PIN值, 采用DES算法, 命令报文数据域如下格式:

PIN密文值(16字节)
用旧PIN值, 对数据 (8字节旧PIN值, 8字节新PIN值) 进行加密保护, 生成16字节密文, 新PIN 或者旧PIN长度不足8字节, 以'FF'右填充;卡片收到指令时, 验证旧PIN值, 通过后更新PIN值。

如果P1 = '01', 更新已有的PIN值, 采用SM1算法, 命令报文数据域如下格式:

PIN密文值(32字节)
用旧PIN值, 对数据 (16字节旧PIN值, 16字节新PIN值) 进行加密保护, 生成32字节密文, 新 PIN或旧PIN长度不足16字节, 以'FF'右填充;卡片收到指令时, 验证旧PIN值, 通过后更新PIN值。

8.17.4 响应报文数据域

响应报文数据域不存在

8.17.5 响应报文状态码

此命令执行成功的状态码为'9000'。

IC卡可能回送的警告状态码如下表所示:

状态码	含义
'6581'	内存失败
'6700'	长度出错
'6982'	安全条件不满足
'6985'	使用条件不满足
'6A80'	数据结构不正确
'6A81'	功能不支持
'6A84'	空间不足

附录 A 基本数据文件 (EF)

表 A.1 卡片信息数据文件

文件标识(SFI)		‘12’ (十进制)
文件类型		透明
文件大小		30
文件存取控制		读 = 自由 改写 = 需要验证 PIN
字节	数据元	长度
1	发卡方应用版本	1
2-11	应用序列号	10
12-13	卡片制造商信息	2
14-15	支持算法信息	2
16-23	发卡方标识符	8
24-27	上一次应用更新日期	4
28-30	上一次应用更新时间	3

表 A.2 公钥数据文件

文件标识(SFI)		‘10’ (十进制)
文件类型		特殊的线性变长
文件大小		
文件存取控制		读 = CHV 改写 = 需要验证 PIN
字节	数据元	长度
1	公钥私算法标识	1
2	密钥属性	1
3	ACV (‘00’ 表示自由使用该公钥, ‘01’ 表示需要验证 PIN 才能使用该公钥, 其他值无效)	1
4	公钥 ID (PKID)	1
5	公钥参数信息	1
6-7	密钥长度	2
8-X	公钥值	X-8

其中, 公钥算法标识字节的编码如下:

B1	B2	B3	B4	B5	B6	B7	B8	说明
0	0	0	0		0			
				X				密钥格式
				0				高字节到低字节 (正序)
				1				低字节到高字节 (倒序)
						X	X	非对称算法
						0	1	RSA算法
						1	0	SM2算法

密钥属性字节编码如下:

B1	B2	B3	B4	B5	B6	B7	B8	说明
0		0	0	0				RFU

	X							公钥是否允许被覆盖
	0							否
	1							是
					X			是否允许用于Verify Signature命令
					0			否
					1			是
						X		RFU
							X	是否允许用于Decipher/Encipher命令
							0	否
							1	是

密钥ID的编码如下：

B1	B2	B3	B4	B5	B6	B7	B8	说明
0	0							RFU
		X	X	X	X	X	X	值

表 A.3 私钥数据文件

文件标识(SFI)		‘11’ (十进制)
文件类型		特殊的线性变长
文件大小		
文件存取控制		读 = 禁止 改写 = 需要 验证 PIN
字节	数据元	长度
1	私钥算法标识	1
2	密钥属性	1
3	ACV (‘00’ 表示自由使用该私钥, ‘01’ 表示需要验证 PIN 才能使用该私钥, 其他值无效)	1
4	私钥 ID (SKID)	1
5	私钥参数信息	1
6-7	密钥长度	2
8-X	私钥信息列表 (SIL)	n
8-X+n	私钥值	m

除私钥参数信息字节、密钥属性字节和私钥信息列表外，私钥数据文件中其他字节的编码与公钥数据文件中的相应字节编码相同。

其中，私钥参数信息等于RFU；密钥属性字节编码如下：

B1	B2	B3	B4	B5	B6	B7	B8	说明
0		0	0	0		0		RFU
	X							私钥是否允许被覆盖
	0							否
	1							是
					X			是否允许用于Compute Digital Signature命令
					0			否
					1			是
							X	是否允许用于Decipher/Encipher命令

							0	否
							1	是

私钥信息列表（SIL）与相应密钥分量在私钥文件记录中的组成格式如下：

私钥信息列表							私钥		
SIL长度	I1	L1	I2	L2	In	Ln	私钥分量1	私钥分量2	私钥分量n
1字节	[SIL长度]字节						L1	L2	L3

SIL包含了私钥分量的长度和顺序等信息，其中，In字节编码如下：

B1	B2	B3	B4	B5	B6	B7	B8	说明
0	0	0	0					RFU
				X	X	X	X	私钥分量类型
				0	0	0	0	n RSA 公钥
				0	0	0	1	p RSACRT 私钥
				0	0	1	0	q RSACRT 私钥
				0	0	1	1	d RSACRT 私钥
				0	1	0	0	d mod (p - 1) RSACRT 私钥
				0	1	0	1	d mod (q - 1) RSACRT 私钥
				0	1	1	1	1/q mod p RSACRT 私钥
				1	0	0	0	SM2 公钥
				1	0	0	1	SM2 私钥分量 1
				1	0	1	0	SM2 私钥分量 2
				1	0	1	1	SM2 私钥分量 3
				1	1	0	0	SM2 私钥分量 4
				1	1	0	1	SM2 私钥分量 5

表 A.4 证书数据文件

文件标识(SFI)		‘13’（十进制）
文件类型		透明
文件大小		4096
文件存取控制	读 = 自由	改写 = 需要验证 PIN
字节	数据元	长度
1-4096	证书内容值	4096

附录 B 非对称密钥的装载

1. 用 Update Record 命令装载私钥

私钥通过一条 Update Record 命令写入到私钥数据文件。

通常，密钥在被使用前，COS 必须先验证该密钥的长度字节与实际密钥值长度是否一致，若验证通过，则该密钥可以通过 Manage Security Environment 命令的指定而被使用。

私钥的装载过程如下图 B.1 所示。

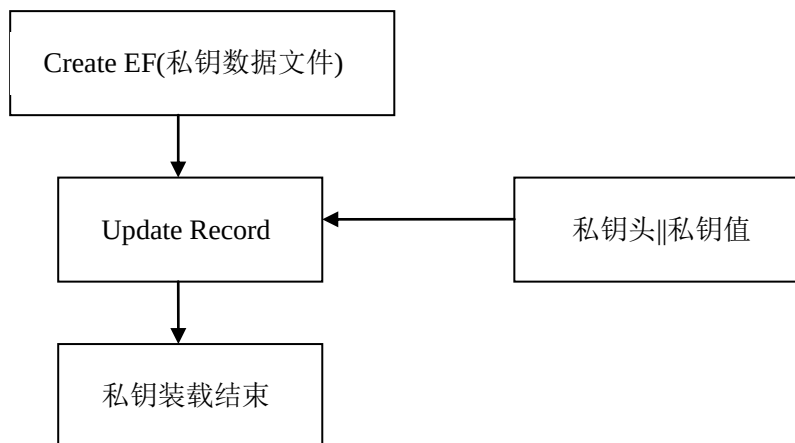


图 B.1 Update Record 命令装载私钥流程

考虑到安全因素，通常不采用外部加载私钥的方式，而是直接通过 Generate Asymmetric Key 在卡片内部直接生成公私钥对，私钥永不出卡，从而确保私钥的私密性和安全性。

2. 用 Update Record 命令装载公钥

公钥通过一条 Update Record 命令写入到公钥数据文件。

通常，密钥在被使用前，COS 必须先验证该密钥的长度字节与实际密钥值长度是否一致，若验证通过，则该密钥可以通过 Manage Security Environment 命令的指定而被使用。

公钥的装载过程如下图 B.2 所示。

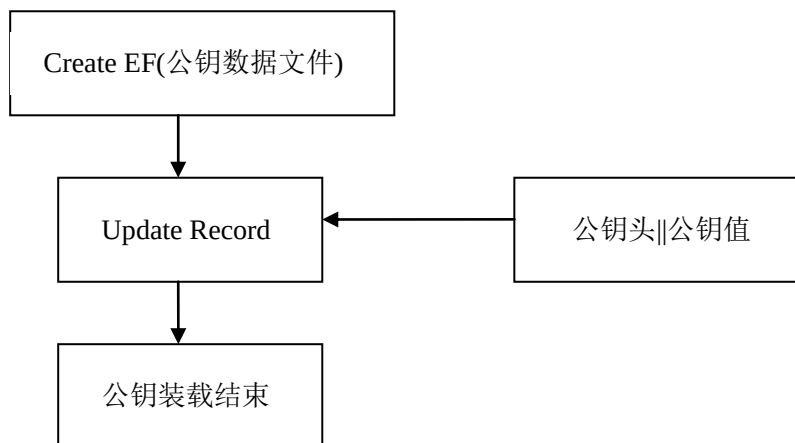


图 B.2 Update Record 命令装载公钥流程

3. 用 Generate Asymmetric Key 命令同时装载（生成）公钥和私钥

在使用 Generate Asymmetric Key 命令同时装载公钥和私钥前，必须保证：私钥的密钥头和公钥的密钥头已由 Update Record 命令分别装载到私钥数据文件和公钥数据文件中。同时私钥的 SKID 和公钥的 PKID 必须保持一致。装载过程如下图 B.3 所示。

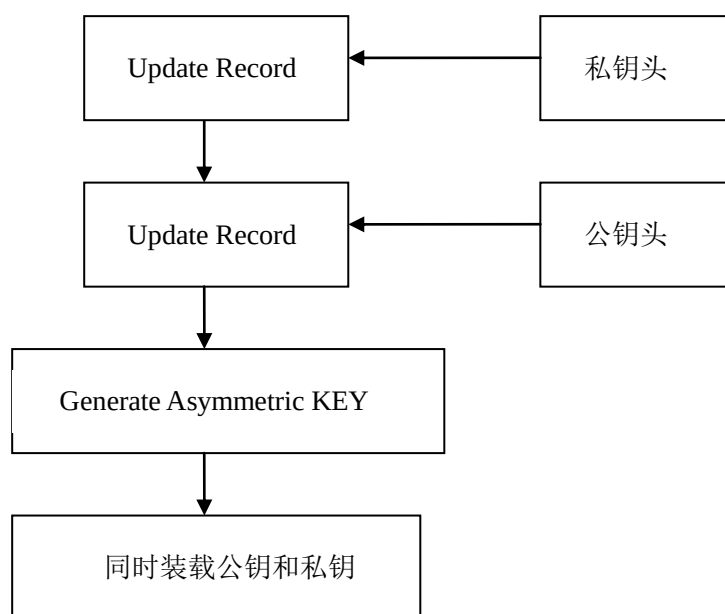


图 B.3 Generate Asymmetric Key 命令同时装载私钥和公钥流程

附录 C 读卡终端配置建议

为确保交易安全，本部分描述了数字证书应用 IC 卡对读卡终端的建议要求，并不是强制要求。按照安全级别的不同，I 型与 II 型终端在硬件配置要求上有所区分。

表 C.1 读卡终端配置建议

终端硬件部件	I型	II型
显示屏	可选型 (Optional)	必备型 (Mandatory)
IC卡接口	必备型 (Mandatory)	必备型 (Mandatory)
确认按键	必备型 (Mandatory)	必备型 (Mandatory)
取消按键	必备型 (Mandatory)	必备型 (Mandatory)
数字键盘	可选型 (Optional)	必备型 (Mandatory)
上翻按键	可选型 (Optional)	可选型 (Optional)
下翻按键	可选型 (Optional)	可选型 (Optional)
USB通讯接口	必备型 (Mandatory)	必备型 (Mandatory)
汉字扩展字符集	可选型 (Optional)	可选型 (Optional)